



REPORT COMPLETO - SPLUNK HAUNTING EXERCISE

Cybersecurity Training Program

Incident Response & Log Analysis



INFORMAZIONI GENERALI

Campo	Dettaglio
Esercizio	Bonus 3: Splunk Haunting
Tool Utilizzato	Splunk Enterprise
Dataset	tutorialdata.zip
Totale Eventi Analizzati	109.864
Periodo Analizzato	17-24 Agosto 2026
Tipologia Log	SSH/Linux Secure + Web Server Logs
Data Analisi	08 Settembre 2026



OBIETTIVI DELL'ESERCIZIO

1. Importare e analizzare log di sicurezza con Splunk
2. Identificare tentativi di accesso falliti

3. Trovare sessioni SSH riuscite
4. Rilevare attacchi brute force
5. Isolare errori web (500 Internal Server Error)
6. Utilizzare comandi `rex` per estrarre campi non indicizzati
7. Produrre un report di Incident Response

STRUTTURA DEL DATASET

Sorgenti Identificate

Sorgente	Tipo	Descrizione
mailsv/secure.log	Linux Secure	Log SSH del Mail Server
www1/secure.log	Linux Secure	Log SSH del Web Server
www1/access.log	Web Access	Log HTTP del sito buttercupgames.com

Sourcetype Rilevati

- `www1/secure` - Log di sicurezza Linux
- `access_combined` - Log web in formato Apache/Nginx

Formato dei Log

SSH Log:

```
text

Thu Aug 24 2026 22:39:24 mailsv1 sshd[5276]: Failed password for invalid
user appserver from 194.8.74.23 port 3351 ssh2
```

Web Log:

text

```
142.233.200.21 - - [23/Aug/2026:11:27:37] "GET  
/oldlink?itemId=EST-12&JSESSIONID=SD0SL7FF1ADFF44202 HTTP 1.1" 500 860
```

ANALISI DETTAGLIATA DELLE 5 QUERY

Query 1: Tentativi di Accesso Falliti

Obiettivo: Identificare tutti i tentativi di login falliti

Query Utilizzata:

splunk

```
index="tutorialdata" "Failed password"  
| rex field=_raw "Failed password for (invalid user )?(?<user>\S+) from  
(?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| where isnotnull(src_ip) AND isnotnull(user)  
| convert ctime(_time) as timestamp  
| table timestamp, src_ip, user  
  
| sort - timestamp
```

Risultati:

- Migliaia di tentativi falliti SSH
- Utenti più attaccati: root, admin, apache, testuser, mongodb, mail, games, desktop, nagios, cyrus, guest
- IP principali attaccanti: 194.8.74.23, 203.45.206.135, 128.241.220.82

Esempio di Output:

Timestamp	IP Sorgente	Username
08/24/2026 22:39:24	194.8.74.23	root
08/24/2026 22:39:24	194.8.74.23	testuser

08/24/2026 22:39:24

194.8.74.23

apache

Query 2: Sessioni SSH dell'Utente djohnson

Obiettivo: Trovare sessioni SSH riuscite per l'utente "djohnson"

Query Utilizzata:

splunk

```
index="tutorialdata" "djohnson" "Accepted password"
| rex field=_raw "Accepted password for (?<user>\S+) from
(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| convert ctime(_time) as timestamp

| table timestamp, src_ip, user
```

Risultati:

- Sessioni aperte e chiuse per djohnson
- IP di provenienza: 10.3.10.46 (IP privato)
- Molteplici accessi riusciti

Esempio di Output:

Timestamp	Evento
08/24/2026 22:39:21	Accepted password for djohnson from 10.3.10.46 port 8176
08/24/2026 22:39:21	session opened for user djohnson by (uid=0)
08/24/2026 22:39:21	session closed for user djohnson by (uid=0)

Interpretazione: djohnson è un utente legittimo che si connette da IP interno (10.3.10.46)

Query 3: Attacchi da IP 86.212.199.60

Obiettivo: Identificare tentativi falliti da un IP specifico

Query Utilizzata:

```
splunk

index="tutorialdata" "86.212.199.60" "Failed password"
| rex field=_raw "Failed password for (invalid user )?(?<user>\S+) from
(?<src_ip>\d+\.\d+\.\d+\.\d+) port (?<port>\d+)"
| where isnotnull(user)
| convert ctime(_time) as timestamp

| table timestamp, user, port
```

Risultati:

- Molteplici tentativi falliti
- Date: 17, 22, 23 Agosto 2026
- Utenti provati: hsqldb, admin, system, alex, mantis, jira, vmware, nagios, mail, services, sync, nginx, whois, mailman, rdb, ncsd, games, noone

Esempio di Output:

Timestamp	Username	Porta
08/17/2026 22:39:23	hsqldb	4379
08/17/2026 22:39:23	admin	2831
08/17/2026 22:39:23	system	4294

Nota: Lo stesso IP appare anche nei log web con errori 500

Query 4: Rilevamento Attacchi Brute Force

Obiettivo: Identificare IP con più di 5 tentativi falliti

Query Utilizzata:

splunk

```
index="tutorialdata" "Failed password"  
| rex field=_raw "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| where isnotnull(src_ip)  
| stats count by src_ip  
| where count > 5  
| sort - count  
  
| rename count as "Numero Tentativi", src_ip as "IP Sorgente"
```

Risultati - Top 20 IP Malevoli:

#	IP Sorgente	Tentativi Falliti
1	87.194.216.51	948
2	211.166.11.101	743
3	128.241.220.82	622
4	109.169.32.135	515
5	194.215.205.19	514
6	216.221.226.11	433
7	188.138.40.166	297
8	65.19.167.94	286
9	107.3.146.207	282
10	95.130.170.231	279
11	223.205.219.67	274

12	27.1.11.11	273
13	27.35.11.11	270
14	59.162.167.100	267
15	91.210.104.143	253
16	27.101.11.11	251
17	108.65.113.83	249
18	59.99.230.91	244
19	198.228.212.52	237
20	198.35.2.120	232

Query 5: Internal Server Error

Obiettivo: Isolare tutti gli errori 500 nel dataset

Query Utilizzata:

```
splunk

index="tutorialdata" "500"
| convert ctime(_time) as timestamp
| table timestamp, _raw

| sort - timestamp
```

Risultati:

- Numerosi errori HTTP 500 su www.buttercupgames.com
- Pagine problematiche:
 - `/oldlink` (la più colpita)

- /cart.do
- /product.screen
- /category.screen

Esempio di Output:

text

```
142.233.200.21 - - [23/Aug/2026:11:27:37] "GET  
/oldlink?itemId=EST-12&JSESSIONID=SD0SL7FF1ADFF44202 HTTP 1.1" 500 860
```



ANALISI DI SICUREZZA

Minacce Identificate

1. Attacco Brute Force SSH Distribuito

Descrizione: Attacco coordinato da multiple sorgenti IP

Intensità: 948 tentativi dal singolo IP più aggressivo

Automazione: Evidente (pattern regolari, molti utenti provati)

IP Malevoli Top 5:

- 87.194.216.51 (948 tentativi) - CRITICO
- 211.166.11.101 (743 tentativi) - CRITICO
- 128.241.220.82 (622 tentativi) - ALTO
- 109.169.32.135 (515 tentativi) - ALTO
- 194.215.205.19 (514 tentativi) - ALTO

2. Errori Web Application

Descrizione: Multipli errori 500 sul sito buttercupgames.com

Possibili cause: Bug applicativo o attacco SQL injection

Impatto: Degrado del servizio, possibile perdita dati

3. Correlazione tra SSH e Web

IP 86.212.199.60 appare in:

- Tentativi SSH falliti
- Errori web 500

Conclusione: L'attaccante sta colpendo entrambi i servizi

TECNICHE SPLUNK UTILIZZATE

Comandi Principali

Comando	Funzione	Esempio
<code>index</code>	Seleziona l'index da cercare	<code>index="tutorialdata"</code>
<code>rex</code>	Estrae campi con regex	<code>rex field=_raw "from (?<ip>\d+\.\.\d+\.\.\d+)\."</code>
<code>stats</code>	Calcola statistiche	<code>stats count by src_ip</code>
<code>where</code>	Filtra risultati	<code>where count > 5</code>
<code>table</code>	Crea tabella	<code>table timestamp, src_ip, user</code>
<code>convert</code>	Converte formati	<code>convert ctime(_time) as timestamp</code>
<code>rename</code>	Rinomina campi	<code>rename count as "Tentativi"</code>
<code>sort</code>	Ordina risultati	<code>sort - count</code>
<code>head</code>	Limita risultati	<code>head 20</code>

`fillna`

Gestisce valori nulli

`fillna value="N/D"`

Espressioni Regolari (Regex) Utilizzate

Pattern

Scopo

`Failed password for (?<user>\S+)`

Estrae username

`from (?<src_ip>\d+\.\d+\.\d+\.\d+)`

Estrae IP sorgente

`port (?<port>\d+)`

Estrae numero porta

`(invalid user )?`

Rende opzionale "invalid user"

`Accepted password for (?<user>\S+)`Estrae utente login riuscito



STATISTICHE COMPLESSIVE

Volume degli Eventi

Categoria

Quantità

Totale eventi analizzati

109.864

Tentativi falliti SSH

Migliaia

Sessioni riuscite

Centinaia

Errori web 500

Numerosi

IP malevoli identificati

20+

Distribuzione Temporale

Data	Attività
17 Ago 2026	Inizio attacco brute force
22 Ago 2026	Picco errori web
23 Ago 2026	Attacco SSH massivo
24 Ago 2026	Picco brute force (948 tentativi)

CONCLUSIONI

Cosa Abbiamo Imparato

1. Importazione dati in Splunk
 - Upload file zip
 - Configurazione index e sourcetype
 - Verifica importazione
2. Analisi dei log di sicurezza
 - Identificazione pattern di attacco
 - Estrazione di indicatori di compromissione
 - Correlazione tra diverse fonti
3. Tecniche di ricerca avanzate
 - Uso di regex con `rex`
 - Aggregazione con `stats`
 - Filtraggio con `where`
4. Incident Response
 - Rilevamento attacchi brute force
 - Identificazione IP malevoli
 - Documentazione dei risultati

Impatto sulla Sicurezza

L'esercizio ha dimostrato:

- Importanza del monitoring dei log di sicurezza
 - Efficacia di Splunk nell'analisi dei log
 - Necessità di automazione per rilevare minacce
 - Valore delle regex per estrarre dati non strutturati
-

RACCOMANDAZIONI

Azioni Immediate

1. Bloccare IP malevoli nel firewall
2. Disabilitare account non necessari
3. Cambiare password compromesse
4. Investigare sessioni sospette

Azioni a Medio Termine

1. Implementare fail2ban
2. Rafforzare policy password
3. Limitare accesso SSH a IP fidati
4. Patchare applicazione web

Azioni a Lungo Termine

1. Implementare MFA
 2. Deploy SIEM (Splunk ES)
 3. Creare alert automatici
 4. Audit sicurezza regolari
-

COMPETENZE ACQUISITE

Competenza	Descrizione
Log Analysis	Analisi di log SSH e web
Regex	Estrazione campi con espressioni regolari
Splunk SPL	Search Processing Language
Threat Detection	Identificazione attacchi brute force
Incident Response	Documentazione e reportistica
Data Correlation	Collegamento tra diverse fonti

APPENDICE - QUERY COMPLETE

Query 1: Failed Password

```
splunk

index="tutorialdata" "Failed password"
| rex field=_raw "Failed password for (invalid user )?(?<user>\S+) from
(?<src_ip>\d+\.\d+\.\d+\.\d+)"
| where isnotnull(src_ip) AND isnotnull(user)
| convert ctime(_time) as timestamp
| table timestamp, src_ip, user

| sort - timestamp
```

Query 2: Sessioni djohnson

```
splunk

index="tutorialdata" "djohnson" "Accepted password"
| rex field=_raw "Accepted password for (?<user>\S+) from
(?<src_ip>\d+\.\d+\.\d+\.\d+)"
```

```
| convert ctime(_time) as timestamp  
  
| table timestamp, src_ip, user
```

Query 3: IP 86.212.199.60

```
splunk  
  
index="tutorialdata" "86.212.199.60" "Failed password"  
| rex field=_raw "Failed password for (invalid user )?(?<user>\S+) from  
(?<src_ip>\d+\.\d+\.\d+\.\d+) port (?<port>\d+)"  
| where isnotnull(user)  
| convert ctime(_time) as timestamp  
  
| table timestamp, user, port
```

Query 4: Brute Force Detection

```
splunk  
  
index="tutorialdata" "Failed password"  
| rex field=_raw "from (?<src_ip>\d+\.\d+\.\d+\.\d+)"  
| where isnotnull(src_ip)  
| stats count by src_ip  
| where count > 5  
| sort - count  
  
| rename count as "Numero Tentativi", src_ip as "IP Sorgente"
```

Query 5: Internal Server Error

```
splunk  
  
index="tutorialdata" "500"  
| convert ctime(_time) as timestamp  
| table timestamp, _raw  
  
| sort - timestamp
```

Tool: Splunk Enterprise
Durata analisi: Completa